Fases

Capturas

Validación

Incidencias

Papelera

Léeme — Proyecto

MEMORIA DE PROYECTO · AWS + CLOUDFLARE

jasancho.com detrás de Cloudflare

Seguridad perimetral para un portfolio y un laboratorio en AWS: DNS y proxy en Cloudflare, cifrado Full (strict), origen cerrado, un formulario que no publica el correo y cabeceras HTTP con nota A+.

JA

José Antonio Sancho Selma

ASIR · Administración de Sistemas Informáticos en Red

A+	12/12	0	0 €
CABECERAS HTTP	PRUEBAS SUPERADAS	IPS DE ORIGEN EXPUESTAS	COSTE MENSUAL

9–11 nov 2026

Documento público

VERSIÓN PÚBLICA

Las IP, los identificadores de AWS y los datos de la cuenta están tapados en todas las capturas.

Terminal

```
$ curl -sI --http3 https://jasancho.com
HTTP/3 200
server: cloudflare
strict-transport-security: max-age=31536000
content-security-policy: default-src 'self'…
```

Contenido

11 elementos · 17 capturas · 1 esquema · A4 · versión pública

NOMBRE		PÁGINA
VISIÓN GENERAL	Resumen	2
CONTEXTO	Punto de partida y objetivos	3
DISEÑO	Arquitectura final	4
FASE 1	DNS de IONOS a Cloudflare	5
FASE 2	Cifrado de extremo a extremo y cierre del servidor	8
FASE 3	Formulario de contacto sin publicar el correo	9
FASE 4	Portfolio en Cloudflare Pages con cabeceras A+	12
FASE 5	Observabilidad	15
PRUEBAS	Validación	17
REGISTRO	Incidencias resueltas	19
CIERRE	Costes, mantenimiento y lo aprendido	21

Cómo leerlo

El proyecto se cuenta en cinco fases, en el mismo orden en que se hicieron. Cada fase explica el problema, la decisión y cómo se comprobó.

Las capturas son reales y van enmarcadas como ventanas. Los recuadros oscuros con texto ámbar marcan datos que se han tapado a propósito.

IP oculta · ID oculto · cuenta oculta

VISIÓN GENERAL

Resumen

En tres días (9-11 de noviembre de 2026) puse toda la infraestructura de jasancho.com detrás de Cloudflare. La IP del servidor de AWS queda oculta, el tráfico va cifrado de punta a punta y el servidor solo acepta conexiones web que vengan de Cloudflare. El portfolio pasó a Cloudflare Pages con cabeceras de seguridad A+ y ahora tiene un formulario de contacto protegido sin publicar mi correo. Todo con el plan gratuito: coste 0 €.

INDICADOR	ANTES	DESPUÉS
IP del servidor de AWS	Visible en el DNS	Oculta tras el proxy de Cloudflare
Acceso web directo por IP	Abierto a todo Internet	Bloqueado: el Security Group solo admite rangos de Cloudflare
Cifrado Cloudflare → servidor	No existía	Full (strict), con validación del certificado de origen
Cabeceras de seguridad del portfolio	F (GitHub Pages no permite configurarlas)	A+ en securityheaders.com
Correo personal en la web	Visible en 13 sitios	0 apariciones; formulario con Turnstile
Protocolo del portfolio	HTTP/2	HTTP/3 (QUIC) con CDN
Coste	—	0 €

NOTA · VERSIÓN PÚBLICA

Por seguridad, este documento no incluye IPs, identificadores de AWS, claves ni capturas de los paneles de administración.

Las capturas que acompañan a cada fase son reales. Las IP del servidor y de casa, los identificadores de AWS (instancia, Security Group, reglas, lista de prefijos) y los datos de la cuenta de Cloudflare están tapados con recuadros marcados como «IP oculta», «ID oculto» o «cuenta oculta»; el resto se ve tal cual.

CONTEXTO

Punto de partida y objetivos

Al terminar las prácticas de la semana 2 del módulo de AWS (Docker, WordPress, Nginx Proxy Manager y Moodle), los servicios estaban publicados directamente en Internet en una instancia EC2. Cualquiera podía conectarse a la IP del servidor y saltarse el dominio. El portfolio, en GitHub Pages, mostraba mi correo personal a la vista de cualquier bot.

El proyecto empezó con una idea pequeña, un formulario de contacto con Cloudflare Turnstile. Para usar Turnstile en condiciones el dominio tenía que gestionarse desde Cloudflare, y eso abrió el resto:

1. Migrar el DNS de IONOS a Cloudflare, decidiendo registro a registro qué pasa por el proxy.
2. Cifrar de extremo a extremo con validación del certificado de origen.
3. Cerrar la «puerta trasera»: que el servidor solo acepte tráfico web que llegue por Cloudflare.
4. Montar el formulario con un backend propio sin servidores y entrega por correo.
5. Llevar el portfolio a Cloudflare Pages para poder fijar cabeceras de seguridad.
6. Vigilar todo: estado de los servicios en vivo y analítica sin cookies.

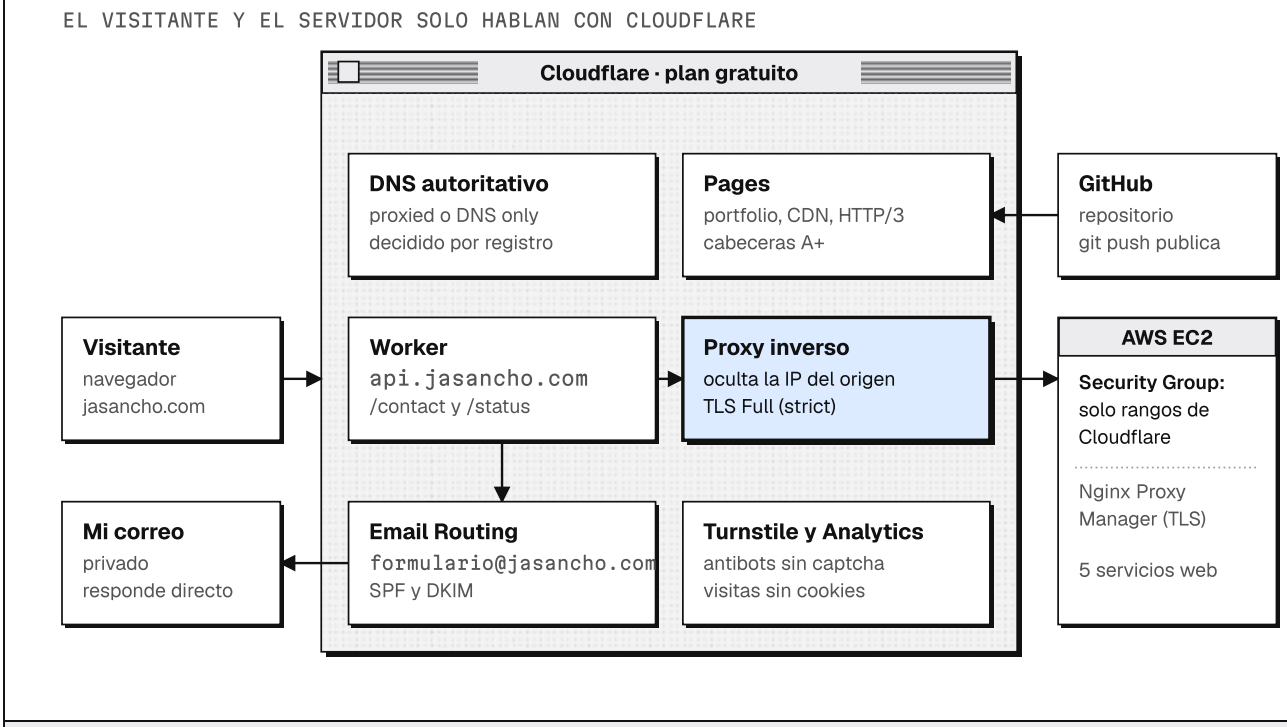
DISEÑO

Arquitectura final

Cloudflare es el DNS autoritativo del dominio y el proxy inverso de los servicios web. El visitante solo ve IPs de Cloudflare, y el servidor de AWS solo acepta conexiones web que vengan de Cloudflare.

GitHub solo guarda el código: cada commit llega a Pages y se publica. El Worker es el único backend: comprueba los servicios del laboratorio a través del proxy y envía los mensajes del formulario por Email Routing.

Arquitectura final



ESQUEMA Cloudflare delante de todo: el visitante y el servidor de AWS solo hablan con Cloudflare.

FASE 1

DNS de IONOS a Cloudflare

El dominio sigue registrado en IONOS, pero sus nameservers ahora son los de Cloudflare: toda la zona se gestiona allí.

1. **Alta del dominio** en Cloudflare (plan Free). Cloudflare escanea la zona de IONOS e importa los registros que encuentra.
2. **Revisión registro a registro.** La importación lo deja todo en *Proxied*, y eso rompe servicios que no son web. Cada registro se dejó en el modo que necesita (tabla).
3. **Cambio de nameservers en IONOS** por los dos que asigna Cloudflare. IONOS avisa de que su zona queda inactiva, que es lo esperado.
4. **Propagación.** Mientras dura, Cloudflare marca «Invalid nameservers». Se comprueba con nslookup -type=ns jasancho.com 1.1.1.1 y, cuando responde, la zona pasa a *Active*.
5. **Limpieza.** IONOS había creado registros de correo (MX, SPF, DKIM y autodiscover) para cada subdominio del laboratorio. No se usaban y bloqueaban Email Routing: se borraron.

CRITERIO FINAL POR REGISTRO

REGISTRO	MODO	MOTIVO
`moodle`, `wordpress`, `proxy`, `prueba`, `docker`	Proxied (nube naranja)	Servicios web del laboratorio: Cloudflare oculta la IP y filtra el tráfico
`jasancho.com`, `www`	Gestionado por Cloudflare Pages	El portfolio (al principio iban en *DNS only* hacia GitHub Pages)
`api`	Proxied	Ruta del Worker; el registro apunta a una IPv6 de descarte (`100::`)
MX, SPF, DKIM	DNS only	El correo no pasa por el proxy

Una consecuencia: Cloudflare solo hace de proxy para HTTP y HTTPS, así que la administración por SSH ya no puede ir por un nombre en naranja. Se hace directamente contra el servidor y con acceso restringido.

Cloudflare — DNS importado

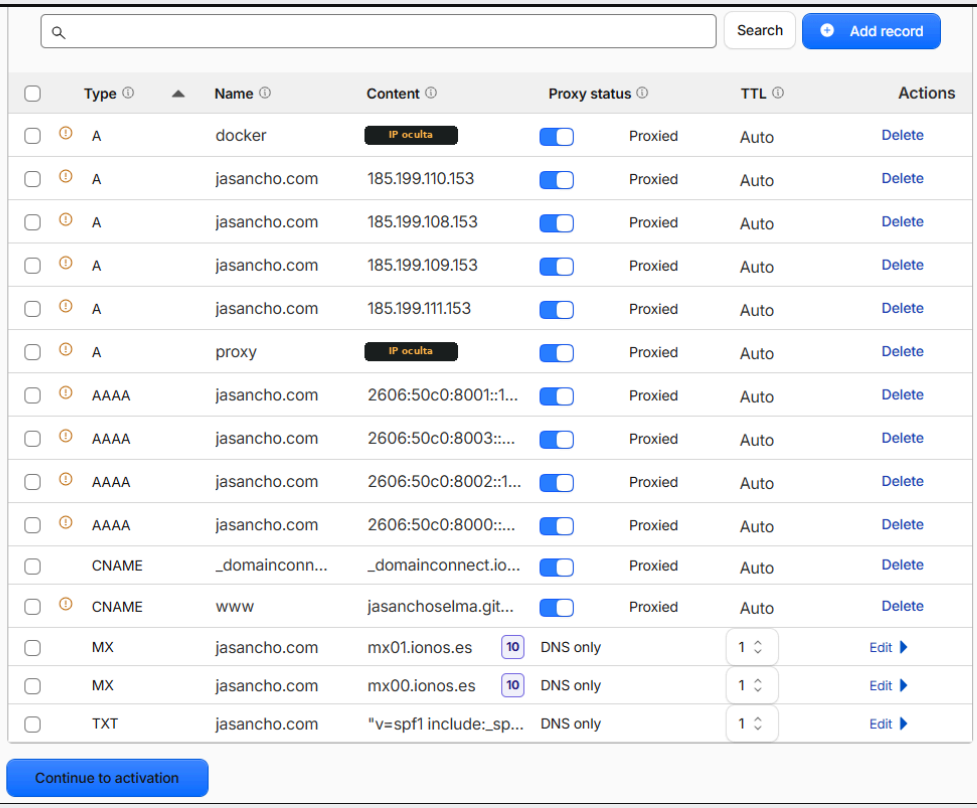


FIG. 1 Cloudflare importa la zona que había en IONOS. Las IP del servidor aparecen ocultas.

IONOS — nameservers



FIG. 2 En IONOS, el dominio pasa a usar los nameservers de Cloudflare.

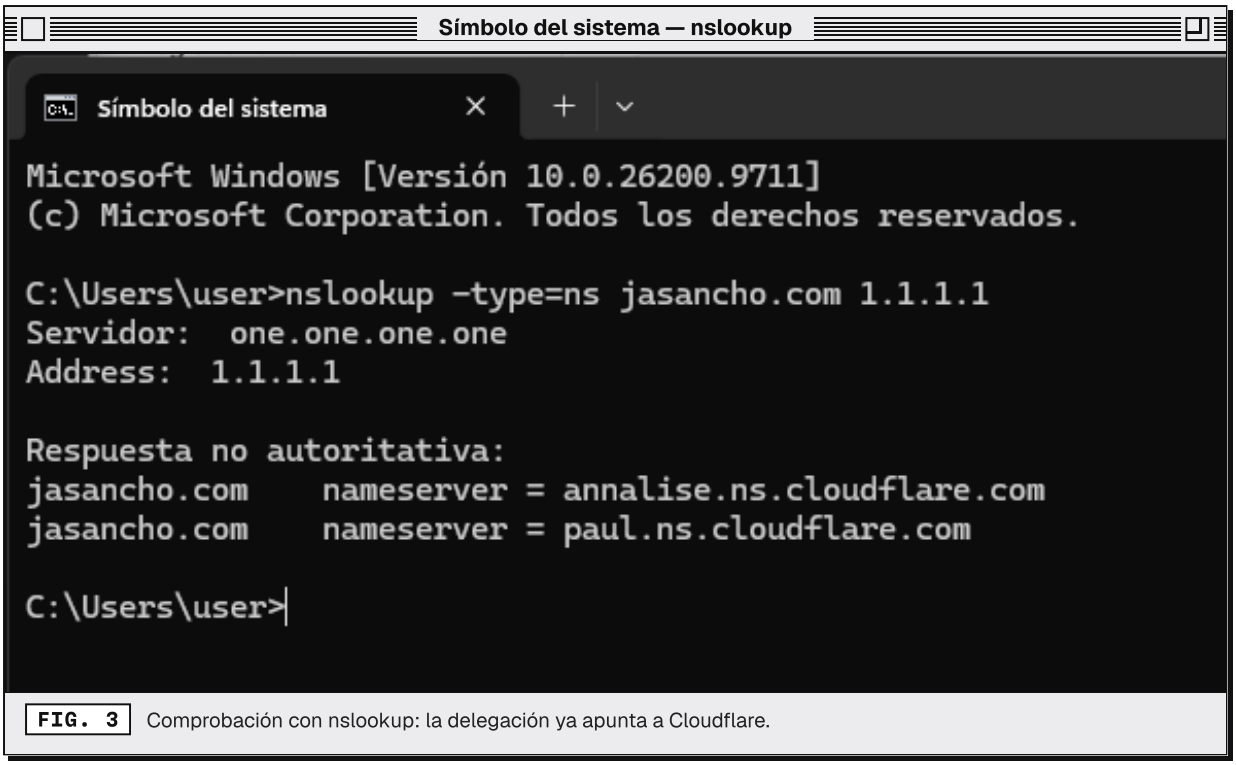


FIG. 3 Comprobación con nslookup: la delegación ya apunta a Cloudflare.

FASE 2

Cifrado de extremo a extremo y cierre del servidor

Cifrado Full (strict). Con este modo, Cloudflare se conecta al servidor por HTTPS y exige un certificado válido para el nombre. Nginx Proxy Manager ya tenía certificados Let's Encrypt, así que funcionó sin tocar el servidor. Además se activó *Always Use HTTPS* y se fijó TLS 1.2 como versión mínima.

MODO SSL DE CLOUDFLARE	TRAMO CLOUDFLARE → SERVIDOR	POR QUÉ NO / SÍ
Flexible	Sin cifrar	El tráfico iría en claro y, con el *Force SSL* del proxy, entraría en un bucle de redirecciones
Full	Cifrado, sin validar el certificado	Acepta un certificado falso: no protege de un intermediario
Full (strict)	Cifrado y certificado validado	**Elegido**

Cerrar la puerta trasera. Con el proxy activo, la IP del servidor seguía aceptando conexiones de cualquiera en los puertos 80 y 443. Quien la conociera, por ejemplo por registros DNS antiguos, podía saltarse Cloudflare.

1. Se creó una **lista de prefijos administrada** en AWS VPC con los 15 rangos IPv4 que Cloudflare publica en cloudflare.com/ips-v4. Una lista se mantiene en un solo sitio y se reutiliza, mejor que 30 reglas sueltas.
2. En el **Security Group** de la instancia se borraron las reglas HTTP y HTTPS abiertas a `0.0.0.0/0` y se crearon de nuevo con la lista de prefijos como origen. AWS no deja cambiar el origen de una regla existente de CIDR a lista de prefijos.
3. El acceso SSH sigue limitado a una única IP de administración.

La lista se creó desde la consola web. No instalé la AWS CLI en la instancia para no dejar credenciales de la cuenta en un servidor expuesto a Internet.

Comprobación: una petición directa a la IP del servidor expira porque el Security Group descarta el paquete. Por el dominio responde HTTP/2 200 porque entra por Cloudflare.

AWS — Security Group

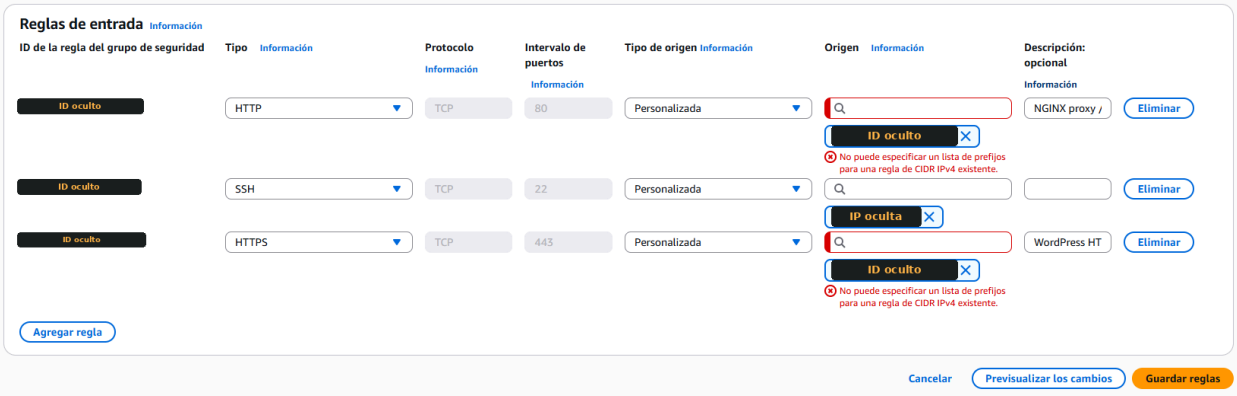


FIG. 4 Reglas de entrada del Security Group: 80 y 443 solo desde la lista de prefijos con los rangos de Cloudflare. Identificadores e IP ocultos.

FASE 3

Formulario de contacto sin publicar el correo

El portfolio es una web estática: necesitaba un backend que validara el antibots y entregara el mensaje. Las claves secretas no pueden ir en el HTML, porque lo lee cualquiera.

OPCIÓN	DECISIÓN	MOTIVO
Web3Forms	Descartada	El envío desde servidor y Turnstile son de pago
Bot de Telegram	Descartada	Funcionaba, pero preferí gestionar los mensajes desde el correo
Cloudflare Worker + Email Routing	**Elegida**	Gratis, todo dentro de Cloudflare y con respuesta directa desde el correo

PIEZAS

- **Turnstile:** antibots sin captcha, autorizado solo para jasancho.com y www. La clave pública va en la web; la secreta solo en el Worker.
- **Worker** `api.jasancho.com`**:** se ejecuta en el borde de Cloudflare, sin servidor. Guarda sus credenciales como *secrets* cifrados del panel, nunca en el código.
- **Email Routing:** recibe el correo de `@jasancho.com` y deja al Worker enviar los mensajes desde `formulario@jasancho.com` a mi buzón, con *Reply-To* al visitante. Los registros SPF y DKIM de Cloudflare evitan que acaben en spam.
- **Interfaz:** una ventana «Nuevo mensaje — Mail» al estilo del Mac clásico, bilingüe, con selector de asunto y un acuse de recibo impreso en papel matricial. Turnstile solo se descarga al llegar a la sección de contacto.

Capas de defensa del Worker, en orden: solo acepta peticiones con origen jasancho.com, descarta en silencio a los bots que caen en un campo trampa invisible, valida los datos, verifica el token de Turnstile en el servidor (incluido el dominio donde se resolvió) y construye el correo con cabeceras codificadas para impedir inyecciones.

Al terminar, mi correo personal aparecía **0 veces** en la web, en `security.txt`, en `humans.txt` y en `robots.txt` (antes estaba en 13 sitios).



FIG. 5 El formulario de contacto: no muestra ningún correo, solo el destinatario y los enlaces públicos (LinkedIn y GitHub). Captura de prueba local con datos de ejemplo.

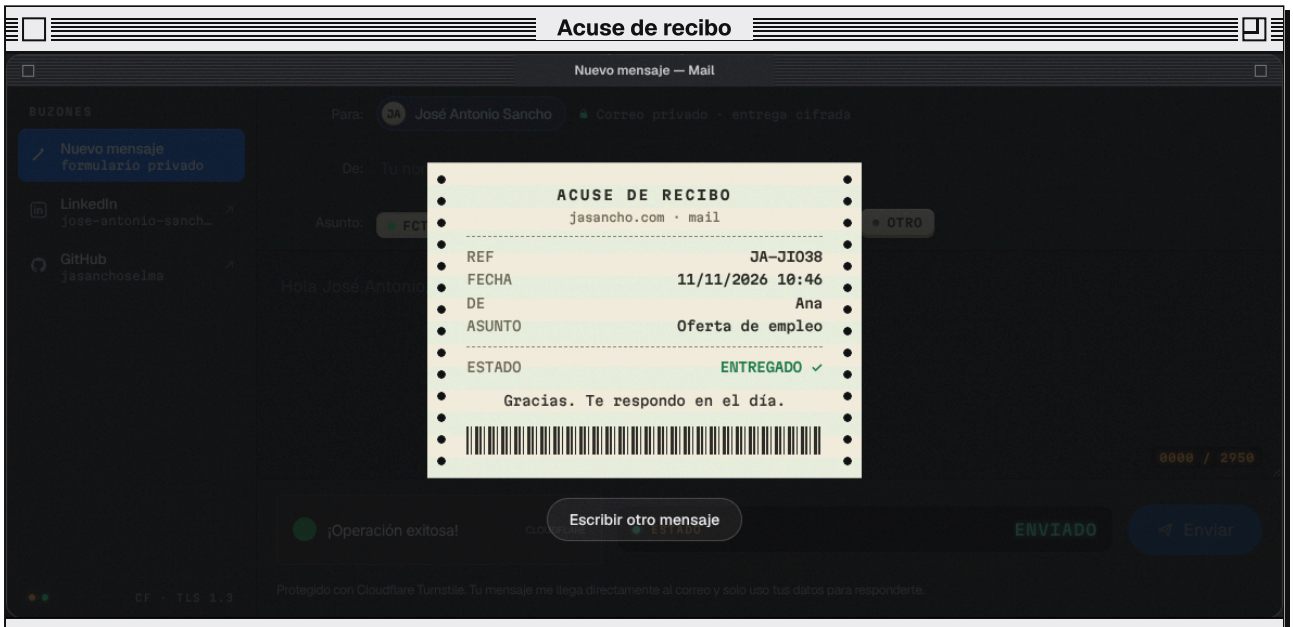


FIG. 6 El acuse de recibo que ve el visitante cuando el Worker confirma el envío.



FIG. 7 Cloudflare Turnstile validando al visitante sin captcha visual.

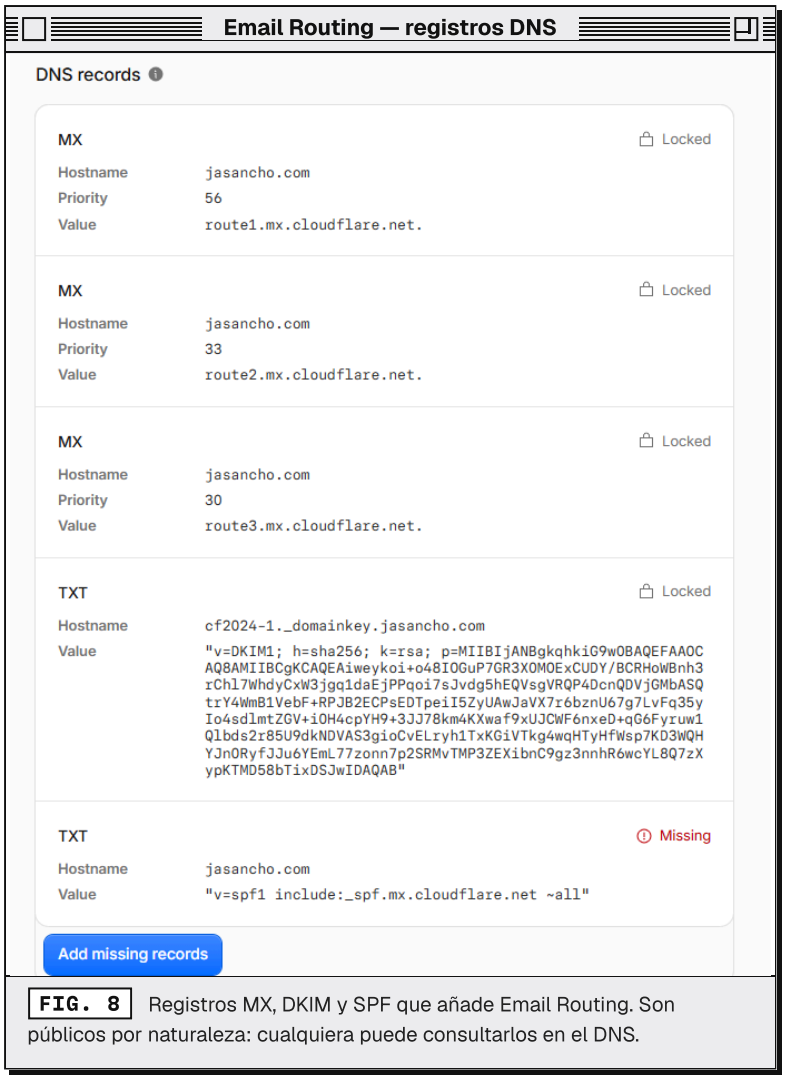


FIG. 8 Registros MX, DKIM y SPF que añade Email Routing. Son públicos por naturaleza: cualquiera puede consultarlos en el DNS.

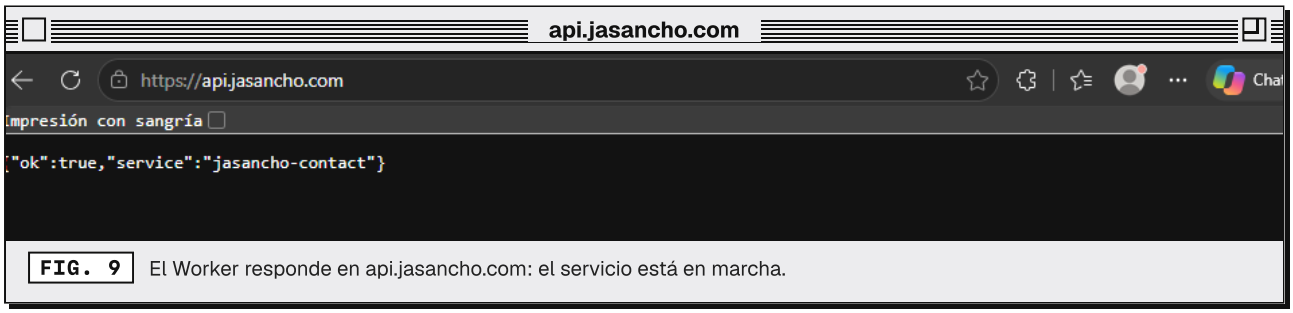


FIG. 9 El Worker responde en api.jasancho.com: el servicio está en marcha.

FASE 4

Portfolio en Cloudflare Pages con cabeceras A+

GitHub Pages no permite configurar cabeceras HTTP, así que el portfolio sacaba una F en securityheaders.com. Lo migré a Cloudflare Pages conectado al mismo repositorio. El flujo de trabajo no cambió: cada commit en GitHub se publica solo en segundos, ahora con CDN y HTTP/3.

MIGRACIÓN SIN PERDER LA WEB

1. Proyecto Pages conectado al repositorio, sin comando de build: la web es HTML, CSS y JavaScript escritos a mano.
2. Prueba completa en la dirección interna `*.pages.dev`: aspecto, nota A+ y consola del navegador sin bloqueos de la CSP.
3. Cambio de dominio: se retiraron los registros de GitHub Pages y se añadieron jasancho.com y www como dominios del proyecto. La web estuvo caída menos de dos minutos.
4. Se desactivó GitHub Pages y se actualizó el contenido de la web que describía el alojamiento.

CABECERAS (ARCHIVO `_headers`)

CABECERA	QUÉ EVITA
Content-Security-Policy	Que se ejecute código inyectado (XSS)
Strict-Transport-Security (1 año, con subdominios)	Conexiones sin HTTPS
X-Frame-Options: DENY	Que otra web incruste la mía (clickjacking)
X-Content-Type-Options: nosniff	Que el navegador «adivine» el tipo de un archivo
Referrer-Policy	Filtrar la URL completa a otras webs
Permissions-Policy	Que un script pida cámara, micrófono, ubicación o pagos

La CSP es estricta: no usa `unsafe-inline` para scripts. Cada bloque de script de la página va autorizado por su **huella SHA-256**, y solo se permiten además Turnstile y la analítica de Cloudflare. Un script en Python recalcula las huellas y regenera `_headers` en cada versión. Sin él, cualquier cambio en el código rompería la web.

Antes de publicarla, probé la política en local con un servidor que aplica las mismas cabeceras y recorrí toda la web con Playwright: escritorio, escenas 3D, formulario, terminal y página 404. Hubo 0 bloqueos. La propia web comprueba sus cabeceras en vivo: la sección Auditoría se pide a sí misma y cuenta las seis.

Cloudflare Pages — despliegues

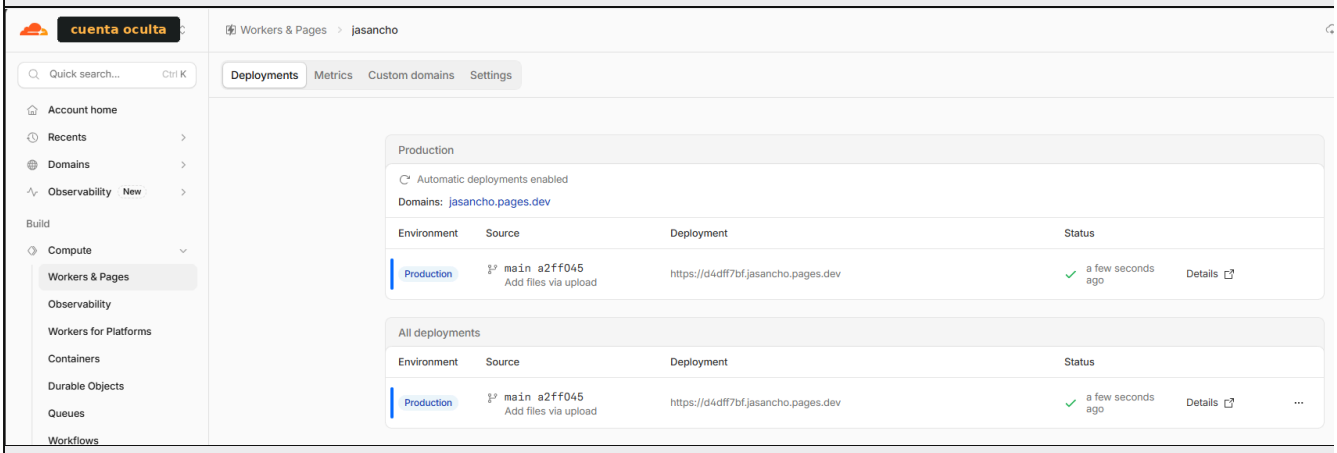


FIG. 10 Cloudflare Pages despliega automáticamente cada commit a main del repositorio público. Nombre de la cuenta oculto.

securityheaders.com

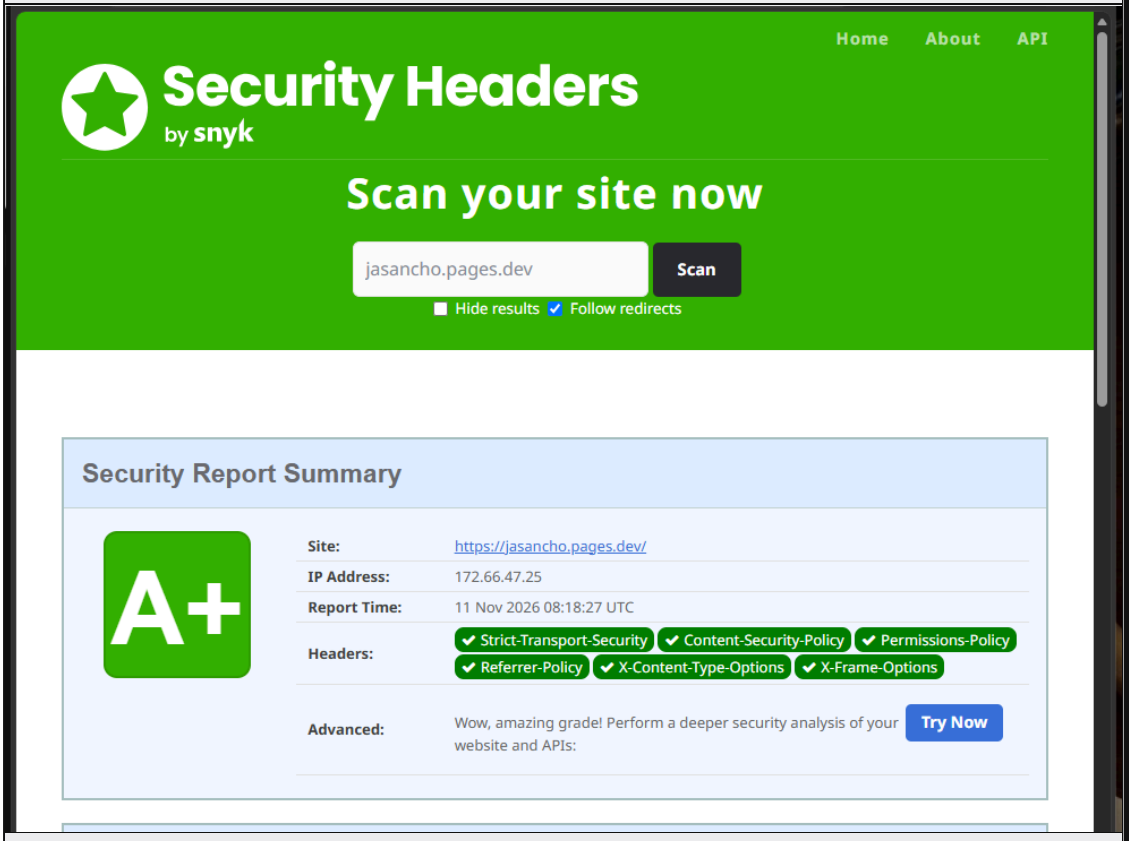


FIG. 11 securityheaders.com da A+ con las seis cabeceras presentes. La IP mostrada es una IP anycast compartida de Cloudflare, no la del servidor.



FIG. 12 La propia web enseña el recorrido real de la petición: DNS en Cloudflare, servido por Pages, HTTP/3 y cabeceras de seguridad.

FASE 5

Observabilidad

Monitor de red. Es una app del escritorio retro del portfolio que muestra en directo el estado de la web, de la API y de los cinco servicios del laboratorio. Cada 30 segundos pide `GET /status` al Worker. El Worker comprueba cada servicio por HTTPS con un límite de 6 segundos y devuelve si responde, el código HTTP y la latencia. El resultado se guarda 30 segundos en la caché de Cloudflare: aunque haya muchas visitas, los servidores reciben como mucho dos comprobaciones por minuto. Los servicios del laboratorio aparecen como «APAGADO» cuando la instancia está detenida, porque se enciende bajo demanda.

El monitor demostró su utilidad el primer día: detectó que `docker.jasancho.com` devolvía un error 525 (ver Incidencias).



FIG. 13 El monitor de red del portfolio: seis servicios en línea y Docker marcado en ámbar.



FIG. 14 Al abrir el subdominio, Cloudflare muestra el error 525: el borde funciona pero el origen no completaba el handshake TLS. Se corrigió en el proxy inverso.

Web Analytics. Cuenta visitas y mide los Core Web Vitals (LCP, INP, CLS) sin cookies ni datos personales, así que no hace falta banner de consentimiento. Gracias a ella vi el CLS en rojo: al abrir un enlace con ancla, la portada crecía después de colocar la sección. Lo corregí y bajó de 0,565 a 0,002.

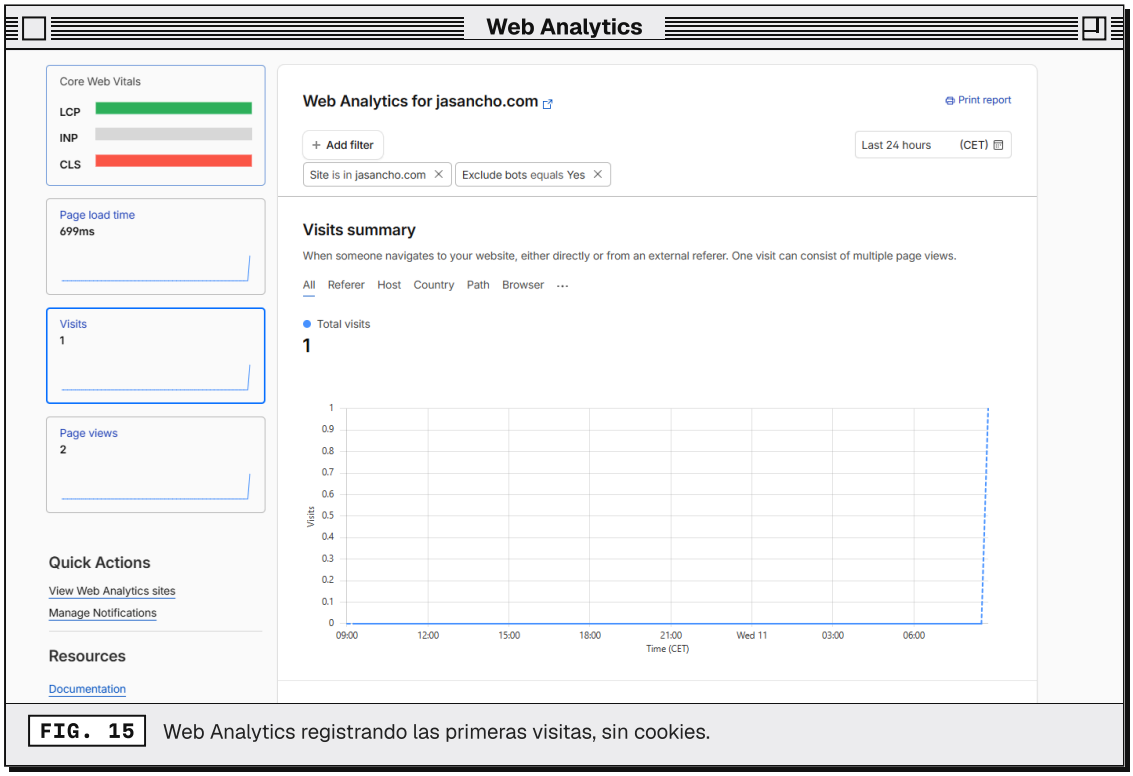


FIG. 15 Web Analytics registrando las primeras visitas, sin cookies.

PRUEBAS

Validación

Las 12 pruebas pasaron.

#	PRUEBA	CÓMO	RESULTADO
1	Delegación DNS	`nslookup -type=ns jasancho.com 1.1.1.1`	Nameservers de Cloudflare, zona *Active*
2	IP oculta	`nslookup` de un subdominio del laboratorio	Devuelve IPs de Cloudflare, no la del servidor
3	Servicios por dominio	`curl -I` a cada subdominio	HTTP/2 200 en todos
4	Servidor detenido	Instancia parada	Error 522 de Cloudflare: el fallo se ve en el borde
5	Acceso directo por IP	`curl -m 10` a la IP del servidor	Tiempo agotado: el Security Group descarta el paquete
6	Worker	Peticiones de prueba válidas y maliciosas	Válida 200 · bot del campo trampa 200 sin envío · email con salto de línea 400 · origen ajeno 403 · captcha falso 403 · dominio ajeno 403 · fallo de envío 502
7	Correo en la web	Búsqueda en `index.html` y en los `.txt`	0 apariciones
8	Envío real	Formulario en jasancho.com	Mensaje recibido; «Responder» va al visitante
9	Cabeceras	securityheaders.com	A+, seis cabeceras en verde
10	CSP	Recorrido completo con Playwright y consola del navegador	0 bloqueos
11	Accesibilidad	axe-core (WCAG 2 AA)	0 fallos de contraste, un solo `h1`
12	Estabilidad visual	Medición de *layout shift*	CLS 0,002 entrando con ancla

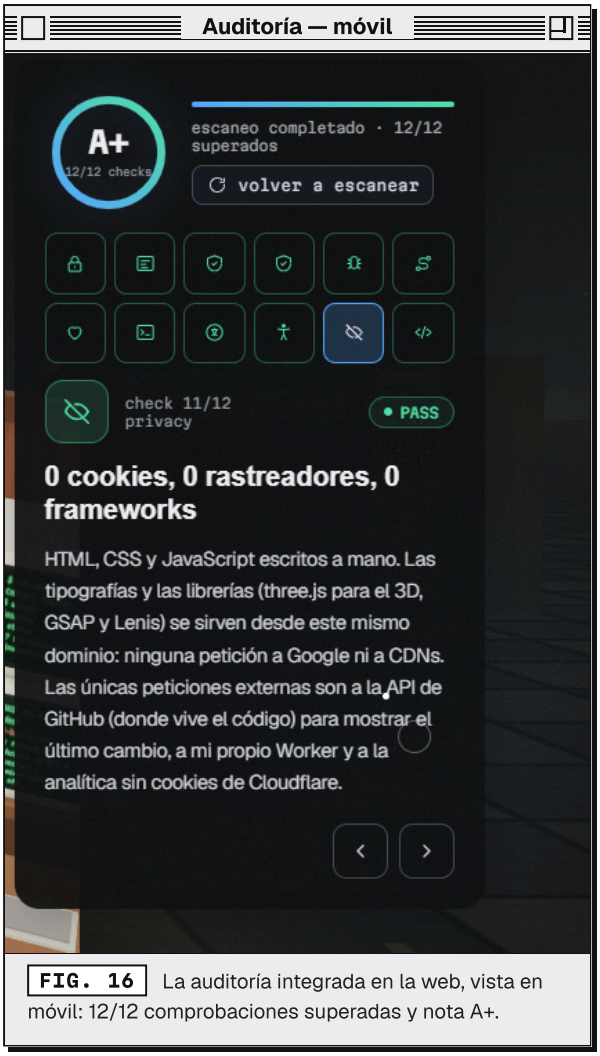


FIG. 16 La auditoría integrada en la web, vista en móvil: 12/12 comprobaciones superadas y nota A+.

REGISTRO

Incidencias resueltas

Surgieron 12 problemas; todos se cerraron con su causa identificada.

FECHA	PROBLEMA	CAUSA	SOLUCIÓN
11/11	CLS en rojo (0,565)	Con `/#ancla`, la portada crecía unos 1.000 px después de colocar la sección	El contenido espera a estar montado y se coloca después: CLS 0,002
11/11	Turnstile da error 110200 en `*.pages.dev`	Ese dominio no está autorizado en el widget	Comportamiento correcto. Se descartó la CSP revisando la consola
10/11	Panel de administración del proxy publicado en un subdominio	Configuración heredada de las prácticas	Retirado de Internet; solo accesible por túnel SSH
10/11	Error 525 en `docker.jasancho.com`, detectado por el Monitor de red	Registro en naranja sin proxy host en Nginx Proxy Manager: openssl s_client devolvía «unrecognized name» (alerta 112)	Proxy host con Let's Encrypt (con *Always Use HTTPS* desactivado unos minutos para el reto HTTP-01)
10/11	«No zones match» al asignar api.jasancho.com al Worker	Fallo del buscador de zonas del panel	Ruta `api.jasancho.com/*` + registro AAAA de descarte en naranja
10/11	Email Routing no se activaba	Registros MX de IONOS en los subdominios del laboratorio	Borrados todos los registros de correo de IONOS
10/11	Web3Forms no servía con Turnstile	Funciones de pago	Backend propio con un Worker
09/11	«No se puede especificar una lista de prefijos para una regla CIDR existente»	AWS no cambia el tipo de origen de una regla	Borrar las reglas 80/443 y crearlas de nuevo con la lista
09/11	CloudShell no arrancaba	Verificación de la cuenta de AWS en curso	Lista de prefijos creada desde la consola web
09/11	`aws: command not found` en la instancia	La CLI no está, ni debe estar, en el servidor	No instalarla para no dejar credenciales en una máquina expuesta
09/11	Error 522	Instancia detenida	Arrancarla: todos los subdominios responden 200
09/11	Todo importado en *Proxied*	Cloudflare activa el proxy en todo lo que importa	Revisión registro a registro

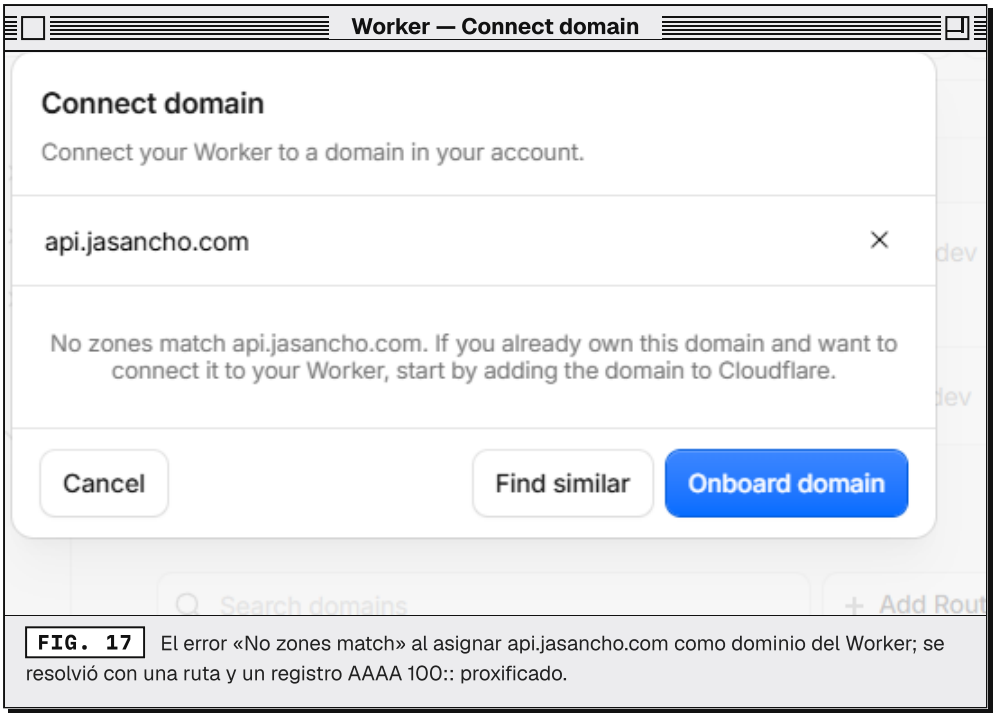


FIG. 17 El error «No zones match» al asignar api.jasancho.com como dominio del Worker; se resolvió con una ruta y un registro AAAA 100:: proxificado.

CIERRE

Costes, mantenimiento y lo aprendido

ELEMENTO	COSTE	MANTENIMIENTO
Cloudflare: DNS, proxy, Pages, Turnstile, Email Routing, Web Analytics	0 € (plan Free)	Ninguno: certificados y despliegues automáticos
Worker	0 € (100.000 peticiones al día incluidas)	Actualizar el código desde el panel cuando cambie
Lista de prefijos y Security Group	0 €	Revisar cloudflare.com/ips-v4 de vez en cuando y añadir los rangos nuevos
Certificados de origen	0 € (Let's Encrypt)	Se renuevan solos. Con Full (strict), uno caducado daría un error 526
Cabeceras de seguridad	0 €	Subir siempre `_headers` junto al HTML: las huellas de la CSP cambian con el código

LO QUE ME LLEVO

- **Defensa en capas.** Ocultar la IP no basta si el servidor sigue aceptando a todo el mundo. Hay que cerrar también el origen, y eso se comprueba atacándolo uno mismo.
- **Medir antes de dar algo por bueno.** El Monitor de red encontró un 525 que nadie había visto, y la analítica destapó un problema de rendimiento que en mi navegador no se notaba.
- **Los secretos no viven en el código.** Las claves privadas están solo en los *secrets* del Worker y la AWS CLI no está en el servidor. Ni este documento ni la web exponen IPs ni credenciales.
- **Migrar sin cortes.** Probar en un entorno paralelo (`*.pages.dev`) antes de tocar el DNS redujo la caída del cambio de hosting a menos de dos minutos.